

Physical Security Requirements

Document ID: GOYA-PHYS-001 **Version:** 1.0 **Status:** Draft **Last Updated:** 2026-08-05 **Owner:** Security Officer

1. Purpose

Define physical security controls for Goya Ledger infrastructure as required by ETSI TS 102 042 §7.4.5 and the Chilean PSC accreditation guide for datacenter operations.

2. Scope

Applies to all facilities housing: - CA servers (root and intermediate) - TSA infrastructure - OSCP responders - Key ceremony equipment - Backup media and HSM devices - Audit log storage

3. Facility Tiers

Tier	Facility Type	Examples
Tier 1 — High Security	Root CA, key ceremony, HSM vault	Air-gapped room, vault
Tier 2 — Operational	Intermediate CA, TSA, OSCP, API servers	Datacenter cage/suite
Tier 3 — Support	Development, staging, monitoring	Office, co-location

4. Tier 1 — High Security Requirements

4.1 Access Control

- Biometric access (fingerprint or iris) + PIN + physical key (dual-factor)
- Minimum two-person rule for entry (no solo access)
- Access list maintained by Security Officer; reviewed quarterly

- All access logged with timestamp, identity, and purpose

4.2 Environmental Controls

- Temperature: 18–24°C with redundant HVAC
- Humidity: 40–60% RH
- Fire suppression: FM-200 or equivalent (no water)
- UPS: minimum 30 minutes runtime + diesel generator
- Flood detection sensors

4.3 Physical Protection

- Reinforced walls, floor, and ceiling
- No windows
- Electromagnetic shielding (TEMPEST-aware for key ceremony)
- Anti-tamper seals on all equipment
- CCTV with 90-day retention

4.4 Key Ceremony Room

- Air-gapped (no network connectivity)
- Faraday cage or RF-shielded
- Dedicated ceremony equipment (never connected to network)
- Witness seating area with clear sightlines
- Secure storage for ceremony records and key shares

5. Tier 2 — Operational Requirements

5.1 Access Control

- Badge + PIN access
- Access logged electronically
- Visitor escort required at all times
- Access revoked within 24 hours of role change

5.2 Environmental Controls

- Temperature: 18–27°C
- Redundant power (UPS + generator)
- Fire detection and suppression
- Cable management (raised floor or overhead tray)

5.3 Network Security

- Physically separated management network
- Locked network cabinets
- Port security (disable unused ports)
- Console access requires physical presence

5.4 Equipment Security

- Server chassis intrusion detection
- Boot integrity (Secure Boot / measured boot)
- Tamper-evident seals on HSM slots
- Disk encryption at rest (see ENCRYPTION-AT-REST.md)

6. Tier 3 — Support Requirements

- Standard office security (badge access, locked doors)
- No production keys or certificates stored
- Development uses simulated HSM (SimulatedHsmProvider)
- Staging environment isolated from production network

7. HSM Physical Security

Requirement	Standard	Implementation
Tamper-evident casing	FIPS 140-3 Level 2+	HSM vendor specification
Zeroization on tamper	FIPS 140-3 Level 3	Hardware feature
Secure key injection	Key ceremony procedure	GOYA-CEREMONY docs
Dual-operator activation	M-of-N custody	CeremonyConfig.threshold
Audit logging	ETSI TS 102 042	AuditAction::KeyGenerated et al.

8. Backup Media Security

- Encrypted at rest (AES-256)
- Stored in fire-rated safe (minimum 2-hour rating)
- Off-site copy at geographically separate facility
- Access requires Security Officer authorization
- Inventory checked monthly; discrepancies trigger P3 incident

9. Visitor Policy

1. All visitors register at reception with government-issued ID
2. Visitor badge issued (visually distinct from employee badges)
3. Escort required at all times in Tier 1 and Tier 2 areas
4. No personal electronic devices in Tier 1 areas
5. Visitor log retained for 7 years (per audit retention policy)

10. Monitoring and Alarms

System	Coverage	Response
CCTV	All Tier 1 and Tier 2 areas	90-day recording retention
Motion sensors	Tier 1 rooms (after hours)	Alarm to Security Officer
Door sensors	All controlled access points	Real-time logging
Environmental	Temperature, humidity, water, smoke	Auto-alert + HVAC failover
Intrusion detection	Perimeter, server chassis	Alarm + P2 incident

11. Compliance Mapping

Requirement	Standard	Section
Physical access control	ETSI TS 102 042	§7.4.5
Environmental protection	ETSI TS 102 042	§7.4.5
Key storage	FIPS 140-3	Level 2/3
Facility security	ISO 27001:2022	Annex A.11
Datacenter requirements	Chilean PSC Guide	Sección 4.3

12. Document Control

Version	Date	Author	Changes
1.0	2026-08-05	Security Officer	Initial draft